

Password Managers

Deep Dive Session



https://docbox.etsi.org/CYBER/EUSR/Open/EN-304-618_V0.1.0_2025-12-23_Password-managers_Mature-draft.pdf



CRA Introduction

- New Legislative Framework
- In Force since Dec 10, 2024
- In Application in Stages
- In Full application by Dec 11, 2027

More?

I wrote a book about it:
Manufacturing European Compliance



Products, not services! The Market! What about Open Source?!!!

All products with digital elements that have an intended and foreseeable use that includes direct or indirect data connection to a device or network will have cybersecurity obligations imposed upon them.

Declaration of Conformity
Presentation of Mark
User Handbook (translated)
Technical Documentation
SBOM (top level)
Cybersecurity Risk Assessment
Evidence
Retention period



EU Standardisation Request

- (2) Harmonised standards play an important role in facilitating the assessment of conformity with those requirements. Products with digital elements which are in conformity with harmonised standards, which translate those essential requirements into detailed technical specifications, should therefore be presumed in conformity with the Cyber Resilience Act.

Harmonised Standards

- **Optional!!!**
- **Important I, II, Critical**
- **Modules A, B+C, H**
- **Presumption of Conformity**



Password Manager Standard



Commission Implementing Regulation (EU) 2025/2392 of 28 November 2025

3. Password managers

Products with digital elements that store passwords, locally on a device or on a remote server, including activities such as generation of passwords as well as password sharing and integration with local or third-party applications for usage of passwords.

This category includes but is not limited to local password managers, password managers provided as browser extensions, enterprise password managers as well as hardware-based password managers.

1. Scope

357 1.1 Password managers

358 The present document focuses on password managers. These are designed to securely store and retrieve passwords and
359 other managed credentials, locally on a device or on a remote server, with a view to facilitate password and credential
360 management.

361 When a password manager includes password checks, password rotation or other active management features it
362 transcends being just a storage tool and becomes an active service that proactively manages credentials over time, this
363 makes it a management service rather than simply a storage tool.

364 1.2 What is a password

365 Passwords are typically associated with user accounts and are a form of secret that users know and use to authenticate
366 themselves to a system. They play a role in secure authentication and access control and verify a user's identity or
367 authorization to access a system or resource. They are integrated into applications, systems and services to verify user
368 identity during login processes. The activity of using a password is the entering of this secret information at
369 authentication points to gain authorized access to protected information.



2. Informative Context

IPRFU (Intended Purpose & Reasonably Foreseeable Use)

- **Securely storing and using secrets**
- **Credentials**
- **Accessing systems by people**



2. Informative Context

HOT TAKE!!!

594 Distinction Clarifications:

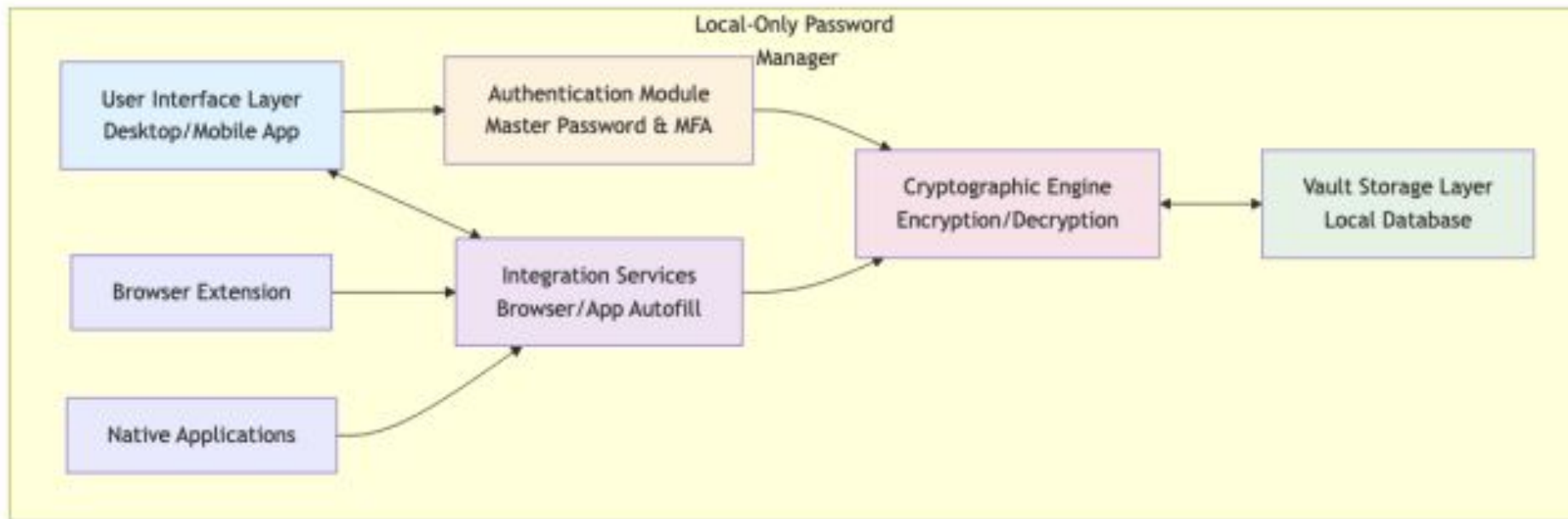
595 While cryptographic keys and API secrets share similar security characteristics with passwords, they are excluded
596 when they authenticate services rather than users.

597 One-time password generation is considered in-scope only when integrated as a persistent feature of the password
598 management system, not as isolated token generation.

599 Environmental dependencies such as operating systems, browsers, and network infrastructure are excluded except
600 where the standard specifies explicit integration requirements.



2. Informative Context Architecture Examples



2. Informative Context: Deployment Use Cases

772 4.4.2.5 Browser-Integrated Password Manager

773 **Description:** Native browser component built into the browser codebase, leveraging browser's security architecture and
774 update mechanisms while providing seamless user experience without additional installation.

775 **Example Environments:**

776 Chrome Password Manager.

777 Safari Keychain integration.

778 Firefox Lockwise.

779 Edge password management.

780 **Risk Considerations:**

781 browser compromise equals vault compromise;

782 limited configurability;

783 vendor lock-in;

784 privacy concerns with browser telemetry.

785 **Risk Level:** MEDIUM (see clause C.5).



2. Informative Context: Specific Use Cases

844 4.4.3.3 UC-PM3: Cloud Password Manager with Local Caching

845 **Description:** Cloud-first architecture with intelligent local caching for frequently accessed credentials, optimizing
846 performance while maintaining cloud-based management and backup.

847 **Example Environments:**

848 Sales team with mobile devices and intermittent connectivity.

849 International travelers requiring offline access.

850 Branch offices with unreliable internet.

851 Emergency response teams in field operations.

852 **Security Characteristics:**

853 selective sync based on access patterns;

854 encrypted cache with TTL;

855 conflict resolution protocols;

856 bandwidth-optimized synchronization.

857 **Risk Level:** HIGH (see clause B.3).



3. Requirements

5.1 Master Password Authentication

5.1.1 Capability

Password manager employs master password authentication mechanism for primary access control.

5.1.2 Condition

MPA-0: Master password authentication controls vault access.

5.1.3 Threat

MPA-T1: Offline brute force attacks against encrypted vaults.

MPA-T2: Online credential stuffing and password spraying attacks.

MPA-T3: Shoulder surfing and keylogger-based credential theft.

MPA-T4: Memory scraping attacks targeting master password in RAM.

5.1.4 Risk

HIGH - Compromise of master password provides complete access to all stored credentials. Likelihood elevated due to targeted nature of password manager attacks.

5.1.5 Requirement

MPA-REQ-1 [MPA-0→MPA-T1] : SHALL implement Key Derivation Function (KDF)



4. Assessments

6 Technical Security Assessments

6.1 Master Password Authentication Tests

6.1.1 Assessment MPA-REQ-1

6.1.1.1 **Reference:** MPA-REQ-1 [MPA-0→MPA-T1]:

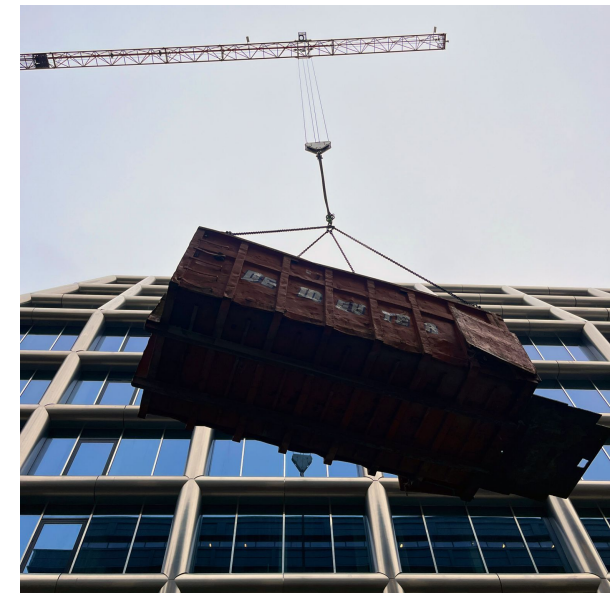
SHALL implement key derivation function (KDF) as described by ENISA.

6.1.1.2 **Given:**

- Password manager application installed with debug/instrumentation build
- Access to configuration files or runtime parameters
- Ability to inspect KDF implementation details

6.1.1.3 **Task:**

Verify the password manager implements a key derivation function with minimum iteration count or equivalent computational cost as specified by ENISA.



Bruno Banelli

4. Assessments

6.1.1.4 Verification:

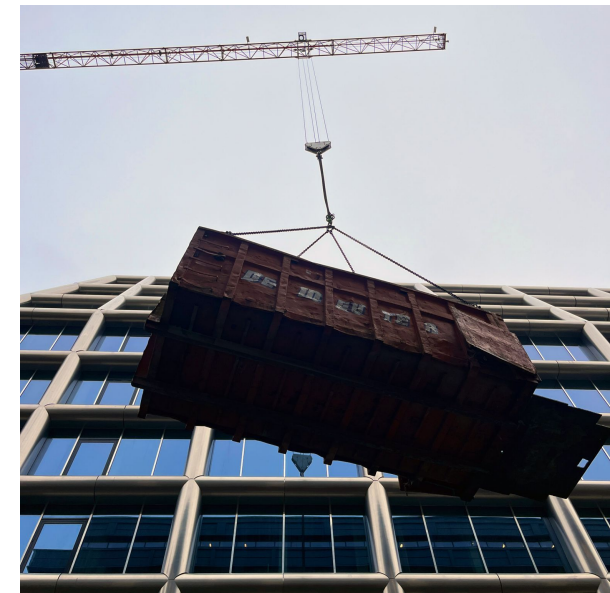
- Inspect captured logs or configuration files for KDF parameters
- Confirm KDF algorithm is from approved list
- Confirm appropriate implementation with code inspection

6.1.1.5 Pass/Fail:

- Pass:** KDF iteration count meets or exceeds minimum threshold, OR alternative KDF meets equivalent computational cost with documented justification
- Fail:** Iteration count below requirements for algorithm, OR unapproved KDF algorithm used, OR no KDF implementation detected

6.1.1.6 Evidence:

- Configuration dump showing KDF parameters
- Debug log file capturing initialization sequence
- Screenshot of KDF settings in administrative interface
- Source code reference showing KDF implementation (if available)



Bruno Banelli

5. References

- [2] ENISA Report 1747792503: “European Cybersecurity Certification Group Sub-group on Cryptography Agreed Cryptographic Mechanisms” (ACM)
- [i.5] FIPS 140-2: "Security Requirements for Cryptographic Modules"
- [i.6] W3C (April 2021) Web Authentication: An API for accessing Public Key Credentials Level 2 (WebAuthn) W3C Recommendation
- [i.7] FIDO (July 2025) Client to Authenticator Protocol (CTAP) 2.2 Proposed Standard



Cyber Resilience Act



Password Manager Standard



EU Standardization Request



Technical Descriptions



Q&A





Thank you for your attention



Co-funded by
the European Union

Follow us on:

